

IO SKY

PRODUCTION READINESS, ACCESS & SECURITY DECISIONS

Developer Handoff

Version 1.0

Status: Production Readiness, Access & Security Requirements

Audience: Senior Full-Stack Developers · Backend · Platform · Security · DevOps · QA

Authoritative developer-facing requirements for the five production-readiness, access and security decisions covered by this handoff.

1. SUPABASE PRODUCTION ENVIRONMENT & CAPACITY

Production must use a genuinely isolated Supabase production environment and must not share Production data, credentials, secrets or environment-specific configuration with Development or Staging.

The required architecture remains:

Development → isolated Development environment

Staging → isolated Staging environment

Production → isolated Production environment

IO SKY will not prescribe an arbitrary Supabase production tier, connection-pool size or database-capacity configuration.

The development team must recommend the appropriate Supabase Production tier and technical database configuration based on:

- the database behaviour already measured during Milestone 2;
- the identified connection-pool capacity-cliff risk;
- expected initial Production workload;
- realistic concurrency;
- appropriate operational headroom;
- Supabase tier and connection/pooling limitations;
- Production reliability requirements.

Before IO SKY approves the Production tier, the development team must provide:

1. the recommended Supabase Production tier;
2. the associated expected recurring cost;
3. the relevant connection and pooling limits of that tier;
4. the proposed Production connection-pool configuration;
5. the assumptions used for expected Production workload and concurrency;
6. the operational headroom provided by the proposed configuration;
7. evidence demonstrating that the previously identified database capacity-cliff risk has been adequately addressed;
8. the load/concurrency testing that will be used to verify the final Production configuration.

IO SKY will approve the commercial tier and associated cost after receiving this technical recommendation.

The development team remains responsible for determining and validating the appropriate technical pool sizing, database-capacity configuration and related implementation.

Production traffic must not be enabled until the approved Production environment and database configuration have been implemented and appropriately load/concurrency tested.

This requirement does not constitute approval to combine Development, Staging and Production or to use logical naming alone as environment isolation. The final Production architecture must maintain genuine separation of Production data, credentials/secrets and environment-specific configuration from Development and Staging.

2. REPOSITORY AUTHORISATION & AUTOMATED DEPLOYMENT

IO SKY approves the use of repository access required to complete and operate the agreed automated deployment workflow, subject to least-privilege access and the environment/access-control requirements below.

Repository access must not be treated as unrestricted access to IO SKY infrastructure, Production systems, credentials or deployment capabilities.

Before access is granted or expanded, the development team must identify:

1. the repository or repositories for which access is required;
2. the individual user or authorised service/integration requiring access;
3. the purpose of the requested access;
4. the minimum repository permission level required;
5. whether the access is required for Development, Staging, Production or multiple environments;
6. whether human repository access, service/integration access or both are required;
7. which automated deployment operations the access will enable;
8. any additional external provider permissions required for the deployment workflow.

Access must follow the principle of least privilege.

Where technically supported, automated deployment should use appropriately scoped service/integration credentials rather than unnecessarily broad personal administrator credentials.

Repository authorisation must not automatically grant Production deployment authority.

Development, Staging and Production deployment permissions must remain appropriately separated. A person or service authorised to deploy to Development or Staging must not thereby obtain permission to deploy to Production.

Production deployment capability must be restricted to specifically authorised identities and workflows.

Protected branches and equivalent repository protections must be used where appropriate to prevent unauthorised or accidental changes to Production-bound code.

The development team must ensure that:

- repository access is attributable to an identifiable authorised user or service;
- shared personal accounts are not used for privileged repository access;
- secrets and Production credentials are not stored directly in source code or committed repository files;
- deployment secrets are managed through an appropriate protected secret-management mechanism;
- repository access can be revoked without requiring application re-architecture;
- removal of a Developer or Technical Operator from an assignment results in removal of access that is no longer required;
- Production deployment cannot be triggered merely by possessing ordinary repository access;
- material Production deployment activity is traceable;
- the automated deployment workflow does not weaken the required Development/Staging/Production isolation.

The development team must document the final automated deployment workflow, including:

- source repository;
- protected branch/release path;

- deployment trigger;
- authorised deployment identity/service;
- target environment;
- required approval controls where applicable;
- secret handling;
- deployment failure handling;
- rollback path;
- access-revocation procedure.

IO SKY will provide or approve the required repository authorisation once the development team has identified the minimum specific access required.

This approval does not constitute blanket authorisation for unrestricted repository administration, Production infrastructure access, secret access or privileged Production deployment.

The final implementation must preserve IO SKY's existing authorization principle:

Role + Permission + Scope + Assignment/Ownership + Environment + Resource.

Repository and deployment access must operate consistently with that principle.

3. CREDENTIAL ROTATION & REPOSITORY HISTORY PURGE

IO SKY gives the development team the go-ahead to remediate the credential exposure identified in the Milestone 2 report, including rotation of the affected credentials and removal of the committed environment file containing live Supabase credentials from repository history.

This authorisation is limited to remediation of the identified security incident and does not constitute general authorisation to rotate unrelated credentials, rewrite unrelated repository history or change unrelated Production configuration.

The development team must first identify and document the complete affected credential set, including at minimum the Supabase keys and database password referenced in the Milestone 2 report, and determine whether any additional secrets contained in the committed file must also be considered exposed.

Any credential present in the committed file or otherwise exposed through the affected repository history must be treated as potentially compromised and assessed for rotation/revocation.

The remediation must include, where applicable:

- rotation or revocation of affected credentials;
- secure replacement with newly generated credentials;
- update of authorised applications, services and environments that legitimately require the replacement credentials;
- removal of the affected environment file and exposed secret material from repository history;
- verification that the old credentials are no longer valid;
- verification that applications and required services continue functioning with the replacement credentials;
- verification that the affected file/secret material is no longer present in the rewritten repository history;
- a new repository and build-artifact secret scan after remediation;
- confirmation that .gitignore and equivalent controls prevent the same class of file from being committed again.

Because purging repository history rewrites published Git history, the development team must coordinate the operation so that active branches, deployments and authorised collaborators are not left using obsolete repository history.

Any required re-cloning, branch synchronisation or other post-rewrite action must be communicated to affected authorised collaborators.

New or replacement credentials must not be transmitted in the remediation report or stored in source code, documentation, tickets, screenshots, logs or other inappropriate locations.

They must be stored and distributed using the appropriate protected secret-management mechanism.

The development team must also review available relevant repository, Supabase, database and application/security logs to determine whether there is evidence of unauthorised use of the exposed credentials during the exposure period.

The absence of identified suspicious activity must not be represented as proof that the credentials were never accessed unless the available logging actually supports that conclusion.

At completion, the development team must provide IO SKY with a remediation record confirming:

1. which credentials/secrets were affected;
2. which credentials were rotated or revoked;
3. confirmation that superseded credentials are invalid;

4. which repository history was purged;
5. confirmation that the exposed material is no longer present in the rewritten history;
6. results of the post-remediation secret scan;
7. confirmation that required applications/services function with the replacement credentials;
8. which relevant security/access logs were reviewed;
9. whether any evidence of unauthorised use was identified;
10. any remaining limitation, unresolved exposure or follow-up action.

This incident was identified in the Milestone 2 report as resulting from the development team's commit of an environment file containing live credentials. The remediation must therefore be tracked and closed as a security defect remediation, with evidence of completion, rather than treated as an ordinary IO SKY-requested feature or scope change.

Production readiness must not be claimed while affected live credentials remain valid or the known exposed secret material remains present in repository history.

4. STAGING.IOSKY.NL & DNS CONFIGURATION

IO SKY confirms that the intended dedicated review/staging address is:

staging.iosky.nl

The current Railway-generated URL may remain available temporarily where technically useful, but it must not be treated as the final public-facing staging address.

The development team must provide IO SKY with the exact DNS record(s) required to connect staging.iosky.nl to the deployed Staging environment, including:

1. DNS record type;
2. host/name;
3. target/value;
4. any verification record required by Railway or another authorised infrastructure provider;
5. any additional DNS configuration genuinely required for the Staging environment.

IO SKY will configure or authorise the required DNS record after receiving these exact values.

The Staging environment must remain clearly separated from Production and must not be made publicly discoverable.

At minimum, Staging must maintain:

- password/authentication protection appropriate to the review environment;
- search-engine noindex protection;
- appropriate robots.txt restrictions;
- HTTPS/TLS;
- isolated Staging configuration;
- Staging-specific credentials and secrets;
- no use of live Production credentials where Staging-specific credentials should be used;
- no dependency on Production data unless explicitly authorised for a specific controlled purpose;
- clear identification that the environment is Staging;
- backend authorization and role/permission enforcement equivalent to the functionality being tested.

Connecting staging.iosky.nl must not convert the Staging environment into Production or weaken the required environment separation.

The required architecture remains:

Development → isolated Development environment

Staging → staging.iosky.nl → isolated Staging environment

Production → production environment / final IO SKY production domain

The development team remains responsible for the technical Railway/domain configuration, certificate provisioning, routing and deployment configuration required to make the Staging hostname operate correctly.

After DNS configuration, the development team must verify and confirm:

- staging.iosky.nl resolves to the correct Staging deployment;
- HTTPS is valid and correctly configured;
- the password/access protection remains active;
- noindex and crawler restrictions remain active;
- no redirect or routing exposes an unintended environment;
- Staging uses the intended Staging configuration and credentials;

- Production remains isolated and unaffected.

The existing Railway URL must not be presented as evidence that the final Production domain or Production environment has been completed.

No Production DNS change is authorised by this requirement. This approval applies only to the Staging environment and staging.iosky.nl.

5. MFA / 2FA / PASSKEY REQUIREMENTS - ALL PLATFORM ROLES

The Milestone 2 report states that Admin, Super Admin and Technical Operator currently have a blocking two-factor authentication requirement, while Client and Developer are not currently gated by MFA.

This is not the final IO SKY security requirement.

The final requirement is:

MFA/2FA must be enforced for all five platform roles:

- Super Admin;
- Admin;
- Developer;
- Technical Operator;
- Client.

No role is exempt solely because of its role type.

The implementation must support secure MFA enrolment, authentication, recovery and lifecycle management appropriate to each role.

At minimum, the final implementation must provide:

1. mandatory MFA enrolment for all five platform roles;
2. enforcement after enrolment so MFA cannot simply be bypassed through another normal login path;
3. TOTP/authenticator-app support as an acceptable MFA method;
4. Passkey support as part of the intended authentication architecture;
5. secure MFA recovery/reset procedures;
6. appropriate re-authentication for security-sensitive MFA/account changes;
7. server-side enforcement rather than frontend-only enforcement;
8. session handling consistent with the platform's authentication and authorization requirements;
9. appropriate auditability of security-relevant MFA/passkey lifecycle events;
10. prevention of one user or delegated role disabling another user's MFA without the required privileged authorization.

MFA recovery must not create a weaker alternative authentication path.

Recovery mechanisms must therefore be designed so that loss of an authenticator or passkey does not allow MFA protection to be bypassed through an inadequately protected reset process.

Privileged MFA administration, reset or recovery actions must be appropriately authorised and auditable.

MFA authentication does not replace authorization.

Successful MFA must not grant access to resources, environments or functionality for which the authenticated user is not otherwise authorised.

The existing authorization model remains authoritative:

Role + Permission + Scope + Assignment/Ownership + Environment + Resource.

Passkeys and MFA are authentication/security controls layered on top of this authorization model.

The current Staging implementation may therefore require modification for Client and Developer so that the final implementation conforms to the all-role MFA requirement.

The development team must test the completed implementation for each of the five roles and confirm that:

- MFA enrolment is enforced;
- subsequent authentication correctly requires the configured second factor/passkey flow;
- recovery/reset operates securely;
- revoked or reset authentication factors cannot continue to be used;
- MFA cannot be bypassed through alternative normal authentication endpoints;
- authentication does not bypass underlying role, permission, scope, assignment, environment or resource authorization.

The final Production platform must not retain the current Client/Developer MFA exemption.

This requirement supersedes the role-specific MFA behaviour described in the Milestone 2 report.